

Bezpečnost ICT 2

Scénář do BUTCA: Útoky na identifikaci a autentizaci

AUTOŘI:
ID:
OBOR:
DATUM VYTVOŘENÍ:

Daniel Prachař a Dalibor Rada
240969, 241090
Informační bezpečnost IBE-3
8. 11. 2023

OBSAH

OBSAH.....	2
Autentizace	3
Požadavky na bezpečné heslo	4
Zneplatnění relace	4
Enumerace uživatelů	4
Ukládání hesel v nezabezpečené podobě	4
Scénář	5
Kontrolní test	9

Autentizace

Autentizace je proces ověření identity uživatele nebo entity, aby se zjistilo, zda má oprávnění k přístupu k určitému systému, službě nebo zdroji. V digitálním světě je autentizace nezbytným nástrojem pro ochranu důvěrnosti a bezpečnosti dat.

Uživatelé obvykle prokazují svou identitu prostřednictvím kombinace faktorů, jako jsou heslo, biometrické údaje (jako otisk prstu nebo rozpoznávání obličeje), karty s čipem nebo certifikáty.

Útoky na autentizaci a protiopatření

Útoky na autentizaci jsou pokusy zneužití procesu autentizace k neoprávněnému přístupu nebo získání povolení, a to bez znalosti nebo souhlasu oprávněného uživatele. Existuje mnoho druhů útoků na autentizaci uživatelů, kdy se útočníci pokoušejí získat neoprávněný přístup k účtům a systémům.

Útok hrubou silou (BruteForce attack):

Útok: Útočník se pokouší uhodnout nebo vyzkoušet všechny možné kombinace hesel, dokud nenajde správnou.

Ochrana: Proti tomuto útoku se lze bránit tak, že použijeme silná a bezpečná hesla a zavedeme mechanismy pro blokování účtu po několika neúspěšných pokusech. Lze využít dvoufaktorové autentizace.

Slovníkový útok (Dictionary attack):

Útok: Útočník se pokouší uhodnout heslo s využitím vlastního nebo již předvytvořeného slovníku. Slovník obsahuje často používané a známá hesla.

Ochrana: Tomuto útoku se lze vyvarovat tak, že použijeme hesla, která nejsou běžná a nejsou jednoduše odhadnutelná. Další možnosti jsou mechanismy zablokování účtu po několika neúspěšných pokusech a dvoufaktorová autentizace.

Phishing:

Útok: Útočník se pokouší získat citlivé informace od uživatele za pomoci falešné webové stránky nebo e-mailu, které se tváří jako legitimní přihlašovací stránky nebo zprávy.

Ochrana: Obezřetnost při otevírání e-mailů a klikání na odkazy. Používat ověřené webové stránky s platným bezpečnostním certifikátem.

Útok mužem uprostřed (Man-in-the-Middle – MITM):

Útok: Útočník sleduje, přerušuje nebo mění komunikaci mezi dvěma stranami tak, aby získal citlivé informace.

Ochrana: Používání zabezpečených protokolů (např. HTTPS, SSL), ověřování certifikátů.

Sociální inženýrství:

Útok: Útočník manipuluje s lidským chováním, aby získal důvěrné informace. Využití této znalosti je například při obnově hesla pomocí bezpečnostních otázek.

Ochrana: Vědomí o této problematice, opatrnost při poskytování informací.

Útok na únik informací o autentizaci:

Útok: Útočník získá informace o autentizaci (hesla, certifikáty, klíče) prostřednictvím úniku dat, nebo jiným způsobem například nalezení fyzického/elektronického souboru s uloženými hesly či hesla uložená v prohlížečích.

Ochrana: Důležité je uchovávat autentizační informace v bezpečném prostředí a šifrované formě nejlépe v zabezpečených aplikacích poskytující správu hesel.

Požadavky na bezpečné heslo

- Heslo by mělo mít minimální délku 12 znaků.
- Heslo by mělo obsahovat alespoň jedno velké a malé písmeno.
- Heslo by mělo obsahovat minimálně jednu číslici.
- Heslo by mělo obsahovat alespoň jeden speciální znak (! ? @ # \$ % ^ & * _ - + () [] { } > < / \ | " ' . ,).
- Heslo by mělo být originální tzn. jedinečné pro každou aplikaci/službu.
- Heslo by se nemělo shodovat s uživatelským jménem nebo emailovou adresou či obsahovat jiné osobní informace.

Dobré praktiky navyšující bezpečnost

- Pravidelně kontrolovat a aktualizovat hesla k aplikacím/službám, tím minimalizujeme riziko.
- Využití dvoufaktorové autentizace (2FA), kromě hesla bude vyžadován další ověřovací prvek, například kód poslaný na mobilní telefon.
- Vyhýbat se heslům, která jsou široce známa (password123).
- Neukládat hesla v prohlížečích ani do jiných textových souborů na počítačích či telefonech.
- Nechovávat hesla ve fyzické podobě (napsané v sešitě/deníčku).

Zneplatnění relace

Relace jsou kritickou součástí dnešních webových aplikací. Díky relacím aplikace rozpoznává jednotlivé uživatele. Uživatel se tak nemusí přihlašovat stále dokola s každým dalším požadavkem. Správně nastavená relace by se po nějaké době, případně nějaké akci, měla zneplatnit (po odhlášení musí k tomuto stavu dospět vždy). V případě špatného nastavení relací je této zranitelnosti možno využít. Např. při využívání jednoho počítače více uživateli.

Enumerace uživatelů

Enumerace uživatelů je druh zranitelnosti, u kterého je jedna z možných příčin selhání identifikace a následného použití automatizovaného útoku. Nejčastěji je tuto zranitelnost možno nalézt na přihlašovací stránce nebo u funkcionality „Zapomenuté heslo“. Útočník sleduje odpovědi serveru, pokud uživatel zadá špatné přihlašovací jméno a aplikace nám vrátí odpověď, že přímo tento uživatel neexistuje, jsme schopni vytvořit seznam uživatelů. Stejně je tohoto možno využít u zadávání hesla. Podobně to může fungovat u zmíněné funkcionality „Zapomenuté heslo“.

Ukládání hesel v nezabezpečené podobě

Další možnou bezpečnostní zranitelností při identifikaci a autentizaci je ukládání hesel v čitelné podobě. Toto se může vztahovat jak na stranu serveru – pomocí SQL Injection je poté možno hesla jednoduše získat, ale zároveň se s tímto problémem můžeme setkat i na straně klienta – uživatel si může ukládat hesla do textových souborů do počítače, mobilu...

Scénář

Využité nástroje: Internetový prohlížeč, program Vmware, virtuální počítač Linux Kali, virtuální počítač PenterepMail, program John the Ripper, 1x Wi-Fi síťová karta — USB, Wi-Fi router nebo Access point, program airmon-ng

Prolog

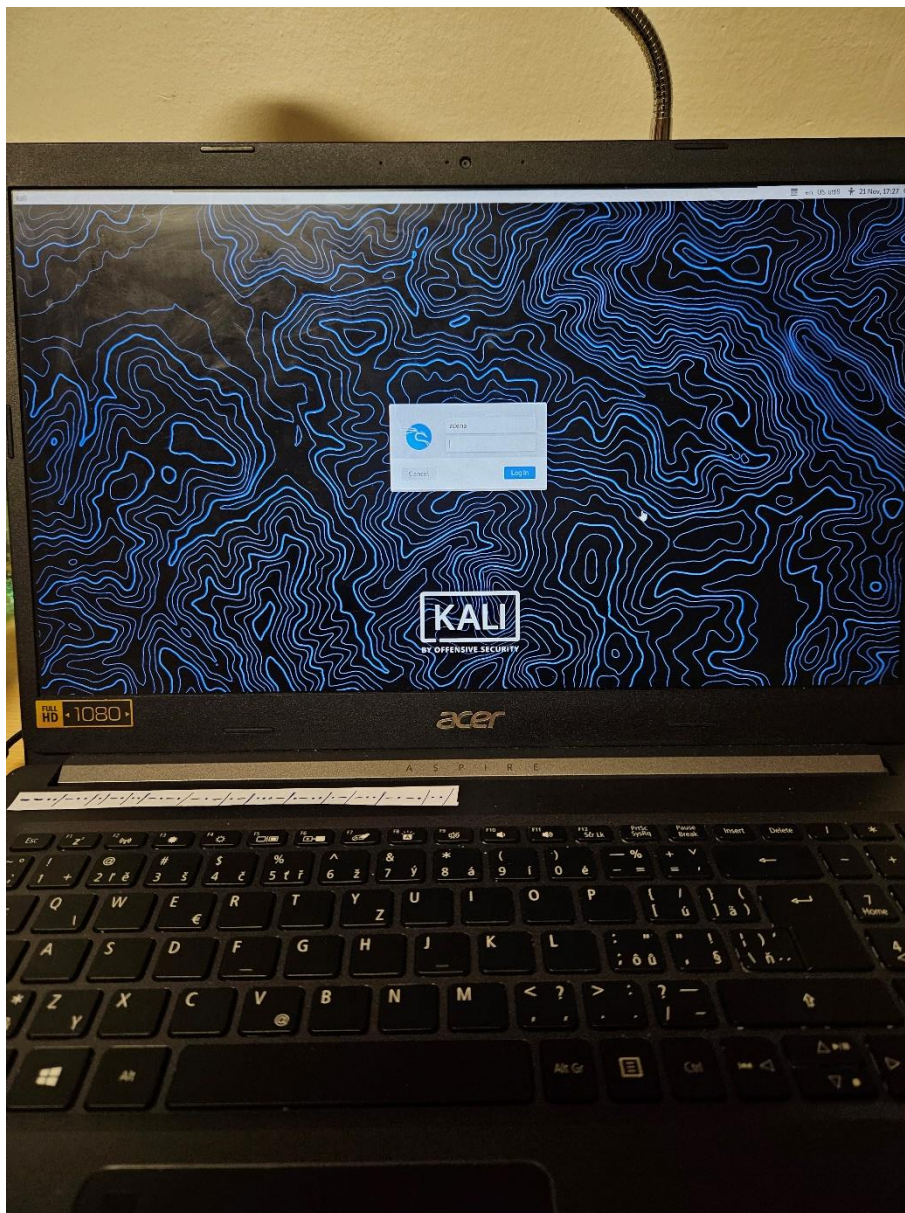
Byl pozdní večer – první máj – večerní máj, a v tu chvíli ti zazvoní telefon. Povzdychneš si a posunutím prstu hovor přijmeš. Na drátě máš našťvaného ředitele společnosti Vládcí oblohy, který tě našel na sociální síti FishBook, kde máš ve svém profilu uvedeno, že pracuješ jako bezpečnostní specialista pro firmu FIB. Ředitel ti řekne, že má podezření na únik citlivých informací o leteckém provozu, a že podezírá některého ze svých zaměstnanců. Pokud nalezneš, kdo za tím stojí nabízí odměnu 100 tisíc. Jelikož si zrovna nezaměstnaný absolvent oboru bezpečnosti vysoké školy TUV a nemáš zrovna peněz na rozhazování tak nabídku bez váhání přijmeš.

Druhý den ráno se vydáváš na kole do firmy Vládcí oblohy. Před vchodem vidíš netrpělivě přešlapujícího muže, který se ti následně představí jako ředitel společnosti. Zavede tě do kanceláře svých zaměstnanců, kde ti popíše situaci: „Někdo z mých zaměstnanců, kteří sdílí tuto kancelář, odesílá citlivá data o pohybu letadel do země, ve které žije živočich Panda Velká“. Řediteli odpovíš ať si s tím nedělá hlavu, a že tomu přijdeš na kloub. Ředitel ti teda popřeje mnoho zdaru a odebere se na oběd.

Úkol 1

Ty se rozhlédneš po kanceláři a před sebou vidíš tři počítače, přistoupíš tedy k prvnímu počítači. Tam je rozjeté přihlašovací okno operačního systému Linux s distribucí Kali s vyplněným přihlašovacím jménem zdena. Nad klávesnicí spatříš zvláštní lísteček. Jaké je heslo?

FLAG: _____



Úkol 2

Přihlásil jsi se úspěšně do počítače Zdeny. Prohledal si soubory v počítači, zkontroloval logy. Nic, co by nasvědčovalo, že krysou ve firmě je Zdena. Napadlo tě zkontrolovat ještě její e-mailovou komunikaci. Zapneš teda firemní mail PenterepMail a chceš se přihlásit. Jaké je heslo?

FLAG: _____

Úkol 3

Dostal jsi se do Zdenina e-mailu, prohledáváš přijatou poštu najdeš zde e-mail od jejího kolegy Miroslava. Ted' už jen zbývá se přihlásit jako uživatel Miroslav a ověřit, jestli je krysou on. (Toto je simulováno přepnutím uživatele v grafickém prostředí a zadáním hesla). Jaké je asi heslo?

FLAG: _____

Úkol 4

Přihlášíš se jako uživatel Miroslav a počkáš, než se načte jeho osobní profil. Míra vypadá, že svůj počítač spravuje dobře vše je perfektně roztřízené do adresářů, podadresářů až po jednotlivé soubory. Snažíš se najít jakoukoliv stopu, která by Miroslava usvědčila, ale nedaří se ti nic najít. Zjistil jsi ale, že Miroslav má osobní email. Otevřeš internetový prohlížeč Mozilla. Jak zjistit přihlašovací jméno a heslo?

FLAG: _____

Úkol 5

Dostal si se do osobního e-mailu Miroslava. Ještě zbývá zkontrolovat jeho firemní e-mail PenterepMail a definitivně se ujistit, že Miroslav není náš špión. Login a heslo do pracovního e-mailu však neznáš. Existuje možnost, jak zjistit heslo přes zapomenuté heslo. Na login se zkus podívat pod lupou. Jaké je heslo?

FLAG: _____

Úkol 6

Úspěšně jsi se přihlásil do firemního e-mailu Miroslava. Jeho e-mailová schránka je prázdná. Miroslav tedy jistě špión není. Zbývá zjistit uživatelské jméno a heslo našeho posledního zaměstnance. Nenašel si však žádné indicie jak přihlašovací údaje odhalit. Napadne tě teda provést SQL injection na celého e-mailového klienta. Zkusíš se podívat na místo kde by mohli být uloženi všichni uživatelé.

Následně za URL adresu zadáš příkaz pro určení počtu sloupců, pomocí kterého se dotaz bude řadit.

Ted' zbývá přijít na číslo, které bude rovno poslední hodnotě, při které se vypíší data. To uděláš tak, že vložíš číslo za příkaz pro řazení a postupně jej budeš inkrementovat od čísla 1 až do čísla, do kdy se vypisují data. Výsledná sekvence tedy bude: URL „příkaz pro řazení“ „číslo“ --+

Nyní můžeš začít odhalovat strukturu databáze. K tomu ti poslouží příkaz:

```
UNION ALL SELECT 1,2, TABLE_NAME, COLUMN_NAME,5 FROM INFORMATION_SCHEMA.columns
```

Zobrazila se ti tabulka databáze a její sloupce. Za pomocí této znalosti můžeš vymyslet SQL příkaz pro odhalení uživatelského jména a hesla. (V jaké tabulce jsou uloženi uživatelé, jaké budou asi názvy sloupců?).

Vypsál jsi všechny uživatele s jejich přihlašovacími údaji, stačí mezi nimi najít našeho posledního zaměstnance a odhalit jeho heslo. Jaké je heslo?

FLAG: _____

Úkol 7

A je to! Přihlásil ses jako uživatel Jirka. Prohledej jeho e-mailovou schránku a zkus najít důkaz o tom, že je krysou. Jako důkaz postačí ID transakce.

FLAG:_____

Úkol 8

Odhalil si špiona!! Avšak nad částkou z výpisu účtu se nestačíš divit. 80 000 € za pár odeslaných e-mailů s informacemi o typu a trase letadel. Zamyslíš se, že zaměstnanec Jirka Hladový musel mít s takovou částkou docela dobrý život. Jen tak sedíš v kanceláři a přemýšlíš, co bys vše za ty peníze koupil – auto, přítelkyni, cestu kolem světa? Smutně si povzdechneš nad svým životem. Co vlastně máš? Bydlíš sám v nájmu na ubytovně na Cejlu. Jako dopravní prostředek ti slouží kolo. Co takhle svůj život zlepšit a pokračovat v tom, co započal Jirka. S tvými znalostmi se přece nenecháš tak snadno odhalit jako on. Vytvoříš si teda v PenterepMailu vlastního uživatele a s využitím předchozích znalostí mu přidělíš administrátorská oprávnění.

FLAG:_____

Epilog:

Uběhl přesně rok od májového večera, kdy ti zavolal ředitel firmy. Ty popíjíš Gin tonic z kokosu na bíle pláži svého soukromého ostrova někde v Karibiku. A uvědomíš si, že před rokem si udělal to nejlepší rozhodnutí ve svém životě.

Kontrolní test

Jaký je účel dvoufaktorové autentizace (2FA)?

- a) Poskytuje dvě hesla pro jednu relaci
- b) Přidává další vrstvu bezpečnosti vyžadující druhý ověřovací prvek
- c) Zjednodušuje proces autentizace

Jaký útok se zaměřuje na sledování, přerušování nebo měnění komunikace mezi dvěma stranami?

- a) Phishing
- b) Slovníkový útok
- c) Man-in-the-Middle útok

Co nepatří mezi požadavky na bezpečné heslo?

- a) Heslo musím mít uložené v šifrovaném a bezpečném správci hesel
- b) Heslo by mělo obsahovat minimálně jednu číslici
- c) Heslo by mělo být originální tzn. jedinečné pro každou aplikaci/službu

Je bezpečné ukládat hesla do internetového prohlížeče?

- a) Ano
- b) Ne

Co znamená termín "spoofing" v kontextu autentizace?

- a) Vytváření falešných internetových stránek
- b) Předstírání identity nebo zařízení tak, aby vypadalo jako legitimní
- c) Používání klamavých e-mailů k získání citlivých informací

Co znamená termín "social engineering" v kontextu autentizace?

- a) Využívání sociálních sítí k ověření identity
- b) Získávání citlivých informací od lidí pomocí klamavých taktik
- c) Proces vytváření silných hesel